

Nombre: Luis Alberto Vargas Gonzalez

Fecha: 27/10/2025

Actividad y unidad: U8 A1. Investigación de la seguridad en comunicaciones cifradas y protección de la privacidad en entornos digitales

Clase: Ciberseguridad.

Maestría en Ciberseguridad.

Protocolos SSL/TLS y su Funcionamiento

¿Qué son SSL y TLS?

SSL (Secure Sockets Layer) es el protocolo criptográfico original diseñado para proveer comunicaciones seguras a través de una red de computadoras. Fue desarrollado por Netscape en la década de 1990. Sin embargo, debido a vulnerabilidades descubiertas, SSL ha sido deprecado.

TLS (Transport Layer Security) es el sucesor moderno y más seguro de SSL. Aunque comúnmente la gente sigue usando el término "SSL" (o SSL/TLS), el protocolo que se utiliza hoy en día es exclusivamente TLS (actualmente en sus versiones 1.2 y 1.3).

Propósito Principal: El objetivo fundamental de TLS es establecer un **canal de comunicación seguro, autenticado y privado** entre dos aplicaciones, comúnmente un navegador web (cliente) y un servidor web. Lo identificas fácilmente en tu navegador cuando ves el ícono de un candado y la URL comienza con `https://`.

¿Cómo Garantizan la Seguridad?

TLS no es un único algoritmo, sino un **conjunto de protocolos (protocol suite)** que utiliza una combinación de técnicas criptográficas para cumplir tres objetivos de seguridad clave: la tríada CIA (Confidencialidad, Integridad y Autenticidad).

1. Confidencialidad (Cifrado)

Evita que terceros (como un atacante en la misma red Wi-Fi) puedan "escuchar" y entender la comunicación.

- **Cómo funciona:** Una vez que se establece la conexión, toda la información (como tus contraseñas, números de tarjeta de crédito o mensajes) se cifra. TLS utiliza **criptografía simétrica** (como AES) para este proceso, ya que es muy rápida y eficiente.
- **El problema:** Para que tanto el cliente como el servidor usen cifrado simétrico, ambos necesitan compartir la *misma clave secreta*. ¿Cómo intercambian esa clave de forma segura a través de un canal público (Internet) sin que nadie más la vea? La respuesta a esto se da durante el "handshake" (apretón de manos) inicial, donde se usa **criptografía asimétrica** para negociar de forma segura esa clave simétrica compartida.

2. Integridad (Autenticidad de los Datos)

Asegura que la información enviada por el servidor sea exactamente la misma que recibe el cliente, sin que haya sido alterada (intencional o accidentalmente) en el camino.

- **Cómo funciona:** TLS adjunta un **Código de Autenticación de Mensaje (MAC)** o (en versiones más modernas como TLS 1.3) un **AEAD (Authenticated Encryption with Associated Data)** a cada paquete de datos.
- Este MAC es como una "firma" o "sello" digital único (un *hash*) del contenido del mensaje. El remitente lo calcula usando la clave simétrica compartida.
- El receptor recibe el mensaje, calcula su propio MAC del contenido y lo compara con el MAC que venía adjunto. Si los dos MAC coinciden, el mensaje está intacto. Si no coinciden, TLS descarta el paquete y la conexión puede terminarse, protegiendo al usuario de datos corruptos o manipulados.

3. Autenticación (Identidad del Servidor)

Quizás la parte más crucial. Garantiza que te estás conectando al servidor que *dices* que te estás conectando (por ejemplo, que estás hablando con `Mi-banco.com` y no con un impostor que se hace pasar por tu banco).

- **Cómo funciona:** Esto se logra mediante **Certificados Digitales** (que también investigarás más adelante) y **criptografía asimétrica** (de clave pública/privada).
- Cuando se conecta a un servidor HTTPS, este te presenta su Certificado Digital.
- Este certificado es como un pasaporte o una identificación oficial emitida por una tercera parte de confianza llamada **Autoridad de Certificación (CA)** (como Let's Encrypt, DigiCert, GlobalSign).
- El navegador verifica que:
 - El certificado fue emitido por una CA en la que confía.
 - El certificado no ha expirado.
 - El nombre de dominio en el certificado (ej. www.google.com) coincide con el dominio al que intentas acceder.
- Si todo esto es correcto, el navegador confía en que el servidor es quien dice ser y procede con la conexión segura. Esto previene eficazmente los ataques de suplantación de identidad (phishing) y *Man-in-the-Middle (MITM)*.

Pasos del Handshake SSL/TLS y Logro de la Tríada CIA

El establecimiento de una conexión segura no es instantáneo. Ocurre a través de un proceso de negociación llamado **Handshake (apretón de manos)**. Este proceso es una serie de mensajes de ida y vuelta entre el cliente (tu navegador) y el servidor (el sitio web) *antes* de que se transmita cualquier dato de la aplicación (como la solicitud HTTP de la página).

El objetivo principal del handshake es:

1. Autenticar al servidor.
2. Acordar los algoritmos criptográficos que se usarán (la *Cipher Suite*).
3. Generar y compartir de forma segura las claves simétricas que se usarán para cifrar la sesión.

Aunque los pasos exactos varían ligeramente entre **TLS 1.2** (aún muy común) y **TLS 1.3** (el estándar moderno, más rápido y seguro), el proceso conceptual es el siguiente:

Pasos Clave del Handshake (Conceptual)

1. **Client Hello (Hola, Cliente):** El cliente inicia la comunicación.
 - a. Envía un mensaje al servidor diciendo: "Hola, quiero establecer una conexión segura. Soporto estas versiones de TLS (ej. 1.2, 1.3) y estos algoritmos de cifrado (llamados *Cipher Suites*). Aquí tienes un número aleatorio (Cliente Random)".
 - b. En TLS 1.3, para ahorrar tiempo, el cliente también envía proactivamente su parte de la clave (un *key share* basado en Diffie-Hellman).

2. **Server Hello (Hola, Servidor) y Certificado:** El servidor responde.

- a. "Hola, cliente. De las versiones y algoritmos que me ofreces, he decidido que usaremos esta versión de TLS (ej. 1.3) y esta *Cipher Suite* específica (ej. TLS_AES_256_GCM_SHA384)".
- b. "Aquí tienes mi número aleatorio (Servidor Random)".
- c. **¡Paso crucial (Autenticidad)!**: El servidor envía su **Certificado Digital**. Este certificado contiene su clave pública y está firmado por una Autoridad de Certificación (CA) de confianza.
- d. En TLS 1.3, el servidor también envía su *key share*.

3. **Verificación del Cliente y Generación de Claves:** El cliente recibe la respuesta del servidor.

- a. **Verificación (Logro de la Autenticidad)**: El navegador verifica la validez del certificado del servidor: ¿Fue emitido por una CA de confianza? ¿No ha expirado? ¿El dominio del certificado coincide con el sitio al que se intenta acceder? Si todo está en orden, el cliente confía en el servidor.
- b. **Generación de Claves:** Usando los *key shares* intercambiados (el del cliente del paso 1 y el del servidor del paso 2), ambos, cliente y servidor, realizan un cálculo matemático (basado en Diffie-Hellman). Mágicamente, **ambos llegan al mismo resultado** (un "secreto maestro" o *Máster Secret*), sin haberlo transmitido directamente por la red.
- c. A partir de este *Máster Secret*, ambas partes derivan un conjunto de **claves de sesión** (las claves simétricas que se usarán para cifrar).

4. Finished (Finalizado):

- a. Para confirmar que todo el proceso fue exitoso, ambas partes envían un mensaje final llamado "Finished".
- b. Este mensaje "Finished" es el **primer dato que se cifra** utilizando la nueva clave de sesión simétrica que acaban de generar.
- c. Si el cliente puede descifrar el "Finished" del servidor y el servidor puede descifrar el "Finished" del cliente, el handshake se completa con éxito.

Cómo se Logra la Confidencialidad, Integridad y Autenticidad

- **Autenticidad:** Se logra en los pasos **2 y 3 del handshake**. El servidor se autentica ante el cliente presentando su **Certificado Digital**. El cliente valida este certificado contra su almacén de CAs confiables. Esto asegura que el cliente está hablando con el servidor legítimo y no con un impostor (previniendo ataques *Man-in-the-Middle*).
- **Confidencialidad:** Se logra **después del handshake**. El propósito del handshake (específicamente el intercambio Diffie-Hellman en el paso 3) es crear de forma segura una **clave de sesión simétrica** (ej. una clave AES). Una vez que se envían los mensajes "Finished" (paso 4), toda la comunicación posterior (la solicitud HTTP, las contraseñas, los datos bancarios) se cifra con esta clave simétrica. Un atacante que capture el tráfico solo verá un flujo de datos indescifrables.
- **Integridad:** Se logra **después del handshake**, junto con la confidencialidad. Al derivar las claves de sesión (paso 3), no solo se crean claves de cifrado, sino también **claves de autenticación (claves MAC)**. Cada paquete de datos enviado se combina con un **Código de Autenticación de Mensaje (MAC)**,

que es un *hash* criptográfico del contenido firmado con esta clave MAC. El receptor recalcula el hash y lo compara. Si no coincide, significa que los datos fueron alterados en tránsito, y la conexión rechaza el paquete.

c, d, e) Análisis del Estándar de Cifrado Avanzado (AES)

AES (Advanced Encryption Standard), conocido formalmente como **Rijndael**, es el algoritmo de **cifrado simétrico** por bloques más utilizado y confiable en el mundo. En el cifrado simétrico, se utiliza la **misma clave secreta** tanto para cifrar como para descifrar la información.

AES fue el ganador de un concurso público internacional organizado por el NIST (Instituto Nacional de Estándares y Tecnología de EE. UU.) para reemplazar al antiguo estándar DES, que se había vuelto vulnerable.

1.d) Diseño, Características y Por Qué se Considera Seguro

Diseño y Características

AES es un **cifrado por bloques** basado en una **Red de Sustitución-Permutación (SPN)**. Esto significa que opera sobre bloques de datos de tamaño fijo (128 bits) y aplica repetidamente una serie de transformaciones matemáticas (sustituciones y permutaciones) en "rondas".

Sus características clave son:

- **Tamaño de Bloque Fijo:** AES siempre opera sobre bloques de **128 bits** (16 bytes) de datos.
- **Tamaños de Clave Variables:** Admite tres longitudes de clave diferentes, lo que determina el número de rondas y el nivel de seguridad:
 - **AES-128:** Clave de 128 bits (10 rondas de cifrado).
 - **AES-192:** Clave de 192 bits (12 rondas de cifrado).
 - **AES-256:** Clave de 256 bits (14 rondas de cifrado).
- **Estructura de Rondas:** Cada ronda (excepto la última) consta de cuatro operaciones matemáticas distintas que se aplican al bloque de datos (llamado "Estado"):
 - **SubBytes (Sustitución):** Es una sustitución no lineal donde cada byte del estado se reemplaza por otro según una tabla predefinida llamada **S-Box**. Este paso introduce **confusión** (oscurece la relación entre la clave y el texto cifrado).
 - **ShiftRows (Permutación):** Es un desplazamiento de los bytes en cada fila del estado. Este paso introduce **difusión** (distribuye la influencia de un bit de texto plano sobre muchos bits de texto cifrado).
 - **MixColumns (Permutación):** Una operación de mezcla que combina los bytes dentro de cada columna del estado. Proporciona una difusión adicional.
 - **AddRoundKey:** Se realiza una operación **XOR** entre el estado actual y una "subclave" (Round Key) derivada de la clave secreta principal. Este es el único paso que involucra la clave.

¿Por Qué se Considera Seguro?

1. **Resistencia Criptoanalítica:** Su diseño fue analizado públicamente por criptógrafos de todo el mundo durante años. Su estructura SPN, y especialmente las propiedades matemáticas de la S-Box y MixColumns, lo hacen extremadamente resistente a las dos formas más poderosas de criptoanálisis: el **criptoanálisis diferencial** y el **criptoanálisis lineal**.
2. **Seguridad Basada en el Tamaño de la Clave:** No se conoce ningún ataque práctico contra AES que sea significativamente más rápido que la **fuerza bruta**.
 - a. Un ataque de fuerza bruta implica probar todas las claves posibles.
 - b. Para AES-128, hay 2^{128} claves posibles. Este número es tan astronómicamente grande que, con la tecnología computacional actual y previsible, es imposible de romper en un tiempo razonable (miles de millones de años).
 - c. Para AES-256, hay 2^{256} (claves), la seguridad es aún mayor y se considera resistente incluso a ataques teóricos de computadoras cuánticas.
3. **Eficiencia:** Es muy rápido de implementar tanto en software como en hardware. De hecho, la mayoría de los procesadores modernos (Intel, AMD, ARM) incluyen **instrucciones de hardware nativas (AES-NI)** que hacen que el cifrado y descifrado sea casi instantáneo, permitiendo su uso masivo (como en TLS) sin una sobrecarga de rendimiento notable.

1.c) Fortalezas y Debilidades

Fortalezas

- **Seguridad Comprobada:** Más de dos décadas de análisis público intensivo sin que se haya descubierto un ataque práctico.
- **Estándar Global:** Adoptado por el gobierno de EE. UU. (incluso para información "Top Secret" con AES-256) y utilizado como el estándar de facto en todo el mundo (en Wi-Fi, VPNs, TLS, cifrado de discos, etc.).
- **Eficiencia:** Extremadamente rápido en hardware y software modernos.
- **Simplicidad (Relativa):** Su diseño es más simple y fácil de analizar matemáticamente en comparación con otros cifrados.

Debilidades

Es crucial entender que las "debilidades" de AES rara vez se encuentran en el algoritmo en sí, sino en **cómo se implementa o utiliza**.

- **Implementación Incorrecta:** La mayor debilidad. Si se genera una clave débil, si se reutiliza una clave de forma incorrecta, o si se utiliza un "modo de operación" inseguro (como el modo ECB, que no oculta patrones de datos), la seguridad del cifrado se anula.
- **Ataques de Canal Lateral (Side-Channel):** Esta es la amenaza más realista. El atacante no ataca las matemáticas de AES, sino el dispositivo físico que lo ejecuta.
 - **Análisis de Tiempos (Timing Attacks):** Si la implementación tarda una cantidad de tiempo ligeramente diferente en procesar ciertos datos o claves,

un atacante puede medir estas diferencias para inferir la clave secreta.

- **Análisis de Consumo de Energía:** El atacante mide las fluctuaciones en el consumo de energía del chip mientras cifra para adivinar la clave.
- **Ataques de Caché:** Explotan cómo el algoritmo utiliza la caché de la CPU.

1.e) Vulnerabilidades Conocidas y Ataques Criptográficos

Hoy en día, **no existen vulnerabilidades prácticas conocidas en el algoritmo AES completo** cuando se usa correctamente. Los ataques que se discuten son, en su mayoría, teóricos o solo se aplican a versiones simplificadas ("de rondas reducidas") del algoritmo.

1. Ataques Teóricos (No Prácticos):

- a. **Ataque de "Biclique":** Este es el ataque "más rápido" conocido contra AES completo. Es teóricamente *marginalmente* más rápido que la fuerza bruta (ej. rompe AES-128 en $2^{126.1}$ operaciones en lugar de 2^{128} . Sin embargo, sus requisitos de cómputo y almacenamiento son tan astronómicos que sigue siendo **completamente inviable** en la práctica.
- b. **Ataques de Clave Relacionada:** Estos ataques (como el publicado en 2009) pueden, en teoría, romper AES-256. Sin embargo, requieren que el atacante pueda obtener datos cifrados con múltiples claves que están relacionadas matemáticamente entre sí de una manera específica. En un protocolo seguro como TLS, esto es **imposible** de lograr, ya que las claves de sesión se generan de forma aleatoria e independiente.

2. Vulnerabilidades Reales (Implementación):

- a. Como se mencionó en las debilidades, los ataques de canal lateral son la principal vulnerabilidad.
- b. Otra vulnerabilidad común está en el **modo de operación**. Por ejemplo, el modo **CBC** (Cipher Block Chaining), aunque seguro, es susceptible a ataques de *padding oracle* (como el ataque *POODLE* en SSLv3) si el descifrado y el manejo de errores no se implementan con extremo cuidado.
- c. Es por esto por lo que los estándares modernos exigen modos **AEAD (Authenticated Encryption with Associated Data)**, como **AES-GCM** (Galois/Counter Mode). Estos modos combinan el cifrado (confidencialidad) y la autenticación (integridad) en un solo paso, previniendo la mayoría de estos ataques de implementación.

f, g) Gestión de Claves Criptográficas: Importancia, Desafíos y Mejores Prácticas

1.f) Importancia de la Gestión Adecuada de Claves

Un principio fundamental de la criptografía moderna (Principio de Kerckhoffs) es que **un sistema criptográfico debe ser seguro incluso si todo sobre el sistema, excepto la clave, es de dominio público.**

El algoritmo AES, por ejemplo, es público; cualquiera puede leer su especificación. Su seguridad no radica en el secreto del *método*, sino en el secreto de la *clave*.

Por lo tanto, la gestión de claves criptográficas es, sin duda, el aspecto más crítico de cualquier sistema de seguridad. Un algoritmo robusto como AES-256 es inútil si la clave de 256 bits se almacena en un archivo de texto plano llamado `clave.txt` en el escritorio del servidor.

Analogía: AES es como la bóveda de un banco, fabricada con el acero más resistente del mundo. La clave criptográfica es la combinación de la cerradura. Si la combinación está escrita en una nota adhesiva pegada a la puerta de la bóveda, la resistencia del acero es irrelevante.

La **Gestión del Ciclo de Vida de las Claves** (Key Management Lifecycle) se refiere al conjunto completo de procesos y políticas para manejar las claves desde su creación hasta su destrucción. Si este ciclo se maneja de forma inadecuada, se anula toda la seguridad proporcionada por la criptografía, llevando a:

- **Pérdida de Confidencialidad:** Los atacantes con la clave pueden descifrar todos los datos protegidos.
- **Pérdida de Integridad:** Los atacantes pueden modificar datos y usar la clave para "refirmar" los mensajes (crear un nuevo MAC válido), haciendo que la alteración sea indetectable.
- **Pérdida de Autenticidad:** Los atacantes pueden suplantar la identidad de un usuario o servidor.

g) Desafíos y Mejores Prácticas en la Gestión de Claves

El desafío radica en que las claves son datos, pero son datos *tóxicos*: deben almacenarse y usarse, pero su mera existencia crea un riesgo. A continuación, se detallan los desafíos y las mejores prácticas correspondientes a cada fase del ciclo de vida de una clave.

Fase del Ciclo de Vida	Desafío Principal	 Mejor Práctica
1. Generación	Aleatoriedad Débil: Las computadoras son máquinas deterministas; generar aleatoriedad <i>verdadera</i> es difícil. Si un atacante puede predecir la clave (o parte de ella), la seguridad colapsa.	Utilizar Generadores de Números Pseudoaleatorios Criptográficamente Seguros (CSPRNG) , que se alimentan de fuentes de alta entropía (ej. movimientos del mouse, ruido de hardware) para crear claves impredecibles.
2. Almacenamiento	Custodia Segura: ¿Dónde se guarda la clave? Si se almacena en el mismo servidor que cifra los datos, un atacante que comprometa el servidor (ej. mediante una vulnerabilidad web) robará la clave y los datos.	Hardware Security Modules (HSMs): Dispositivos de hardware especializados y blindados. Las claves se generan <i>dentro</i> del HSM y nunca salen de él. El HSM realiza las operaciones criptográficas internamente. Cloud Key Vaults: (Ej. AWS KMS, Azure Key Vault, Google Cloud KMS). Son, en esencia, HSMs como servicio en la nube.
3. Distribución	Intercambio Seguro: ¿Cómo se entrega una clave simétrica (como la de AES) a dos partes de forma segura a través de un canal inseguro como Internet? (Es el "problema del huevo y la gallina").	Utilizar Criptografía Asimétrica para el intercambio. Como vimos en el handshake de TLS, se usa un protocolo como Diffie-Hellman (ECDH) para que el cliente y el servidor <i>generen</i> la misma clave simétrica de forma independiente, sin transmitirla nunca.
4. Uso y Acceso	Exposición y Privilegio: Si la clave está cargada en la memoria de una	Principio de Mínimo Privilegio: Solo los servicios y usuarios que <i>absolutamente</i> necesitan usar la clave deben tener acceso.

	aplicación, un atacante podría extraerla (ej. un <i>memory dump</i>). Además, es común "hardcodear" claves en el código fuente.	Nunca hardcodear claves: Usar variables de entorno seguras o, idealmente, llamar a un Key Vault/HSM en tiempo de ejecución para <i>usar</i> la clave, sin que la aplicación la "vea".
5. Rotación	Vida Útil de la Clave: Una clave que nunca cambia (estática) es un objetivo valioso. Si se compromete, todo el historial de datos cifrados con esa clave queda expuesto.	Implementar políticas de rotación de claves (ej. cambiar claves cada 90 días). Para conexiones, usar Perfect Forward Secrecy (PFS). Esto significa que cada sesión (ej. cada vez que te conectas a tu banco) genera una clave de sesión simétrica nueva y única. Si un atacante roba la clave de <i>una</i> sesión, no puede descifrar ninguna otra sesión (ni pasada ni futura).
6. Revocación y Destrucción	Eliminación Segura: ¿Qué hacer si una clave se compromete? ¿Cómo se asegura uno de que una clave se borre <i>permanentemente</i> y no sea recuperable de un disco duro?	Tener un proceso claro de revocación (invalidar la clave, lo que veremos con los certificados). Cripto-borrado (Crypto-shredding): En lugar de intentar borrar los datos (lo cual es difícil), simplemente destruya de forma segura la clave maestra que los cifraba. Sin la clave, los datos se vuelven permanentemente ilegibles.

h, i, j) Certificados Digitales: Funcionamiento, Implicaciones y Amenazas

Para que la criptografía asimétrica funcione, el cliente (tu navegador) debe tener la certeza de que la **clave pública** que recibe del servidor (ej. `tu-banco.com`) realmente pertenece a ese servidor y no a un impostor.

Los **Certificados Digitales** son el mecanismo que resuelve este problema de confianza.

1.i) Funcionamiento, Emisión y Establecimiento de la Confianza

Un certificado digital es, en esencia, un **documento de identidad digital** para una entidad en línea (como un servidor web). Su propósito es vincular criptográficamente una **identidad** (ej. el nombre de dominio www.google.com) con una **clave pública**.

El estándar que define su estructura es el **X.509**.

¿Cómo se Emiten? (La Jerarquía de Confianza)

El proceso involucra a tres actores:

1. **El Sujeto (Subject):** El propietario del dominio (ej. la UAG) que desea un certificado.
2. **La Autoridad de Certificación (CA - Certificate Authority):** Una entidad de confianza pública (ej. Let's Encrypt, DigiCert, GlobalSign) que emite los certificados.
3. **El Cliente (Client):** El navegador web que necesita verificar el certificado.

El proceso de emisión es el siguiente:

1. **Generación de Claves:** El Sujeto (UAG) genera un par de claves: una **privada** (que guarda en secreto absoluto en su servidor) y una **pública**.
2. **Solicitud (CSR):** El Sujeto envía su clave pública a la CA, junto con una "Solicitud de Firma de Certificado" (CSR) e información de identidad.
3. **Verificación de Identidad:** La CA debe verificar que el Sujeto realmente es quien dice ser.
 - a. **Validación de Dominio (DV):** La más común. La CA le pide al Sujeto que demuestre control sobre el dominio (ej. subiendo un archivo específico al servidor web o creando un registro DNS).
 - b. **Validación Extendida (EV):** (Menos común ahora) Implica una verificación legal y manual de la existencia y nombre de la organización.
4. **Emisión y Firma:** Una vez verificada, la CA toma la clave pública y la información del Sujeto (dominio, fechas de validez, etc.) y crea el certificado. Luego, la CA usa su **propia clave privada** para **firmar digitalmente** el certificado. Esta firma es el sello de autenticidad.

¿Cómo se Utilizan para Establecer la Confianza? (Cadena de Confianza)

Aquí es donde se conecta con el *handshake* de TLS:

1. **Presentación:** En el *handshake*, el servidor de la UAG envía su certificado (firmado por DigiCert) al navegador del estudiante.
2. **Verificación de la Firma:** El navegador del estudiante **ya confía** en DigiCert. ¿Cómo? Porque el sistema operativo (Windows, macOS, Android) viene con un "**Almacén de Confianza**" (**Trust**

Store) que contiene los certificados raíz (y las claves públicas) de todas las CAs principales.

3. El navegador usa la clave pública de DigiCert (que ya tiene en su almacén) para verificar la firma digital del certificado de la UAG.
4. **Validación:** Si la firma es válida, el navegador concluye: "Este certificado es auténtico y fue emitido por DigiCert, en quien confío. Por lo tanto, puedo confiar en que la clave pública *dentro* de este certificado realmente pertenece a `uag.mx`".

A menudo, esto involucra una "cadena" (un certificado intermedio), pero el principio es el mismo: se debe trazar una línea de firmas válidas hasta un **Certificado Raíz (Root CA)** que esté en el almacén de confianza del sistema.

1.h) Implicaciones de Seguridad y Privacidad

Implicaciones de Seguridad (Positivas)

- **Prevención de Ataques Man-in-the-Middle (MITM):** Esta es la implicación de seguridad más importante. Sin certificados, un atacante en una red Wi-Fi podría interceptar la conexión, hacerse pasar por el servidor del banco, y el cliente no tendría forma de saberlo. El certificado (y la firma de la CA) lo impide.
- **Habilitador de la Confidencialidad:** Al autenticar al servidor, el cliente puede usar de forma segura la clave pública del servidor para el intercambio de claves (como Diffie-Hellman) y así establecer el canal cifrado (con AES).

Implicaciones de Privacidad (Negativas o Colaterales)

- **Pérdida de Anonimato del Servidor:** Por diseño, los certificados exponen públicamente la identidad de un dominio y a quién está asociado.
- **Registros de Transparencia de Certificados (CT):** Para evitar la emisión fraudulenta de certificados, existe un sistema llamado **Certificate Transparency**. Todas las CAs deben publicar cada certificado que emiten en registros públicos y auditables.
 - **Implicación:** Cualquiera (incluidos los atacantes) puede monitorear estos registros. Si tu empresa registra un certificado para `proyecto-secreto.mi-empresa.com`, esa información es pública y revela tus planes.
- **Falsa Sensación de Seguridad:** Los certificados de Validación de Dominio (DV) son fáciles de obtener (incluso gratis). Un atacante puede registrar www.banco-confirmacion.com, obtener un certificado DV válido (el "candado" en el navegador) y montar un sitio de *phishing*. Los usuarios han sido entrenados para "buscar el candado", pero el candado solo garantiza que la conexión está **cifrada**, no que el sitio es **legítimo o seguro**.

1.j) Amenazas y Ataques Relacionados con la Falsificación

A pesar de ser un sistema robusto, la confianza depende del eslabón más débil, que suele ser la CA o el proceso de validación.

- **Compromiso de una Autoridad de Certificación (CA):** El peor escenario. Si un atacante roba la **clave privada de una CA Raíz o Intermedia** (como sucedió con DigiNotar en 2011), puede

emitir certificados fraudulentos *perfectamente válidos* para cualquier dominio (google.com, microsoft.com, etc.). Los navegadores confiarán en ellos implícitamente, permitiendo ataques MITM a gran escala.

- **Emisión Fraudulenta (Sin Compromiso):** Un atacante explota una debilidad en el proceso de **validación de dominio** de una CA. Por ejemplo, si pueden interceptar temporalmente el correo electrónico admin@dominio.com o secuestrar brevemente el DNS (BGP Hijacking), pueden engañar a la CA para que les emita un certificado para un dominio que no poseen.
- **Ataques de Falsificación de Identidad (Homograph Attacks):** El atacante registra un dominio que se ve idéntico a uno legítimo, pero utiliza caracteres de otros alfabetos (ej. www.microsoft.com usando la 'o' cirílica en lugar de la 'o' latina). Pueden obtener un certificado DV válido para este dominio falso y engañar a los usuarios.
- **Fallas en la Revocación de Certificados:** Si un servidor es comprometido y su clave privada es robada, el propietario debe "revocar" el certificado. Los navegadores deben verificar el estado de revocación.
 - **Listas de Revocación (CRL):** Eran listas enormes que los navegadores debían descargar. Muy ineficiente.
 - **Protocolo OCSP (Online Certificate Status Protocol):** El navegador "pregunta" a la CA en tiempo real si el certificado sigue siendo válido.
 - **El Problema (OCSP "Soft Fail"):** Si el servidor de OCSP de la CA no responde (está caído o es bloqueado por un atacante), muchos navegadores **"fallan en modo abierto" (Soft Fail)**, es decir, **aceptan el certificado de todos**

modos para no interrumpir la navegación. Esto crea una ventana de oportunidad para que un atacante use un certificado robado y revocado.

Conclusión: Seguridad, Cifrado y Privacidad en la Era Digital

La presente investigación ha permitido desglosar los mecanismos fundamentales que sostienen la seguridad en las comunicaciones cifradas y, por extensión, la protección de la privacidad en el entorno digital. Ha quedado demostrado que estos dos conceptos son pilares interdependientes: sin comunicaciones seguras, la privacidad es técnicamente inviable.

Hemos determinado que el protocolo **TLS** es el estándar de facto que orquesta la seguridad en la web. Su función no es solo cifrar, sino establecer un canal que cumpla con la tríada CIA (Confidencialidad, Integridad y Autenticidad) a través de un complejo proceso de negociación (*handshake*).

Para lograr la **confidencialidad**, **AES** se erige como el estándar de cifrado simétrico por excelencia. Su diseño matemático, basado en redes de sustitución-permutación, lo ha mantenido resistente a ataques criptoanalíticos prácticos durante más de dos décadas. Sin embargo, su robustez teórica es nula si su implementación es deficiente. Descubrimos que la verdadera vulnerabilidad de AES no reside en el algoritmo, sino en su ecosistema: los ataques de canal lateral y, de forma crítica, la **gestión de su ciclo de vida de claves**. Un algoritmo impenetrable se vuelve inútil si la clave que lo protege es gestionada con negligencia, almacenada de forma insegura o reutilizada indebidamente.

Paralelamente, la **autenticidad** —saber con quién estamos hablando— descansa sobre el ecosistema de **Certificados Digitales** y la Infraestructura de Clave Pública (PKI). Este modelo, si bien es funcional y escalable, basa toda la confianza de Internet en un conjunto de Autoridades de Certificación (CAs). Como se analizó, este modelo introduce un vector de riesgo significativo: el compromiso o la emisión negligente de certificados por parte de una CA puede anular las garantías de autenticidad de la web, permitiendo ataques de suplantación de identidad (MITM) a gran escala.

En resumen, la seguridad en el entorno digital no es un producto estático, sino un proceso dinámico de gestión de confianza, algoritmos y, sobre todo, secretos (claves). La protección de la privacidad del usuario final no es, por tanto, el resultado de un solo "candado" en el navegador, sino la consecuencia de un sistema de seguridad gestionado de forma holística, donde la fortaleza de la cadena criptográfica se mide, inevitablemente, por su eslabón más débil

Referencias Bibliográficas.

1. Cómo funciona el cifrado TLS/SSL | GeoTrust.
<https://www.geotrust.com/es/how-does-tls-ssl-work>.
2. NordLayer. AES Encryption: What is it & How Does it Safeguard your Data? NordLayer. <https://nordlayer.com/blog/aes-encryption/>
3. Arora M. *Que Tan Seguro Es AES a Brute Force?* EE | Times; 2012.
<https://www.eetimes.com/how-secure-is-aes-against-brute-force-attacks/>.
4. ¿Cuáles son las ventajas y desventajas de AES ? EITCA. 2022.
<https://es.eitca.org/cybersecurity/eitc-is-ccf-classical-cryptography-fundamentals/aes-block-cipher-cryptosystem/advanced-encryption-standard-aes/examination-review-advanced-encryption-standard-aes/what-are-the-key-strengths-of-the-advanced-encryption-standard-aes-in-terms-of-its-resistance-to-attacks-and-security/>. Accedido octubre 27, 2025.
5. ¿Cuáles son las mejores estrategias de gestión de claves empresariales? ENTRUST. <https://www.entrust.com/es/resources/learn/best-enterprise-key-management-strategies>.

6. Key Management in Cryptography: A Complete Introduction | Splunk.
Splunk. https://www.splunk.com/en_us/blog/learn/key-management.html.
7. Rojo S. Riesgos ocultos en el uso de los Certificados Digitales.
vintegris.com. <https://www.vintegris.com/es/blog/riesgos-uso-certificados-digitales/>. Published 26 de julio de 2024
8. McAfee. Secure Your Online Communications with Digital Certificates.
McAfee. <https://www.mcafee.com/learn/secure-online-communications-with-digital-certificates/>. Published 13 May 2025.
9. Redtrust. Consecuencias de un ciberataque sobre certificados digitales.
Redtrust. <https://redtrust.com/consecuencias-ciberataque-certificados-digitales/>. Published 15 de febrero de 2022.
10. ¿Qué son SSL, TLS y HTTPS? | DigiCert.
<https://www.digicert.com/es/what-is-ssl-tls-and-https>.